

Hostiggo — Website QA & Functionality Audit

Repository: `aryan-arora/hostiggo-full-website` · **Commit audited:** `c24f7f5` (branch `claude/modest-faraday-clx73f`) · **Date:** 2026-09-29
Stack: Next.js 16.3.1 (App Router) · React 19 · Supabase · Razorpay · Google Maps
Follow-up deep dives: [Homepage destination dropdown](#) — reproduced, root-caused and fix-verified (Medium)

0. Read this first — scope, method and limits

What I could and could not test. The audit sandbox's network policy blocks the three hosts this app depends on — `jhihqmkqvbwniwculhk.supabase.co` (database + auth), `search-service-backend.vercel.app` (search/locations) and `www.hostiggo.com` — and no Supabase, Google Maps or Razorpay credentials were available. I did **not** route around the block. Consequently:

Layer	How it was tested	Confidence
Pages, routing, layout, forms, client-side validation, responsive behaviour	Real — production build (<code>next build && next start</code>) driven by headless Chromium at 1440 / 768 / 390 px	High
Search results, filters, sort, pagination, property page, account/host screens	Real UI, mocked backend — Playwright intercepted <code>/api/*</code> and returned fixture data. Rows are tagged [mocked backend] in the log. This proves what the <i>UI does with</i> the data, not that the real backend behaves the same.	Medium
API authorization, validation, error handling	Real requests to my local build (Supabase pointed at a dead address, so nothing real could be read or changed) plus source review	High for "does it check a token"; unknown for what live RLS would additionally block
Live data, OTP/SMS/email delivery, Google OAuth, Razorpay checkout, Google Maps, image storage, AI import	Not testable — see Section G	—

Nothing destructive was executed (no account deletion/deactivation, no publishing, no payments, no messages to real users). All "authenticated" testing used a **fake session injected into the test browser** against mocked APIs.

Severity note. Findings BUG-001–003 are rated on what the code does. I could not check production infrastructure (Supabase RLS policies, WAF, network rules), so I cannot say whether other controls limit exploitation. I did not exploit them against live data.

Also run (all clean): `next build`  · `tsc --noEmit`  · unit tests 41/41  · ESLint 0 errors / 101 warnings.

A. Executive summary

Metric	Count
Functionalities inventoried (Appendix 1)	121 (65 pass · 29 fail · 27 not tested)
Test cases executed (Section C)	172 — 121 passed · 49 failed · 2 blocked
Page routes crawled	72 routes (+8 edge URLs) × 3 viewports = 240 page loads, 0 crashes
Confirmed bugs	27 —  Critical 2 ·  High 4 ·  Medium 12 ·  Low 9
Potential issues (code-confirmed logic, not reproduced)	2 (BUG-015 High, BUG-016 Medium)
Observations	6 (OBS-01...06)

Test cases and failures are counted per row of the log; a few rows aggregate several controls (e.g. all popular filters), and several failed rows describe the same underlying bug, so **bug counts, not FAIL counts, are the measure of defects**.

The five things to act on first

1.  **The API largely trusts a `userId` sent by the browser instead of verifying the login token** (BUG-001/002/003). Anyone who knows a user's UUID can, per the code, read their login IPs and host contact details; lock their account out permanently; or overwrite their KYC record — and (subject to Supabase RLS, which I couldn't inspect) read/send chats and read bookings as them.
2.  **Two pages show made-up data as if real** — a fake "Your Booking is Confirmed" page (BUG-004) and fabricated reviews with a 4.9★ / 417-review rating (BUG-005).
3.  **Open redirect** on the sign-in flow (BUG-006).
4.  **Search is less functional than it looks** — 8+ filters do nothing, sorting only re-orders the loaded page, and an API failure is shown as "No properties found" (BUG-008/009/010).
5.  **Bookings are switched off site-wide** by a hard-coded flag (`BOOKING_DISABLED = true` , OBS-01), so the core revenue flow cannot currently be completed in the UI.

What works well

Server-side payment code is solid (token-verified, price recomputed server-side, date/guest bounds, HMAC-verified confirm + webhook); Aadhaar validation (Verhoeff) and KYC form gating; logout (storage cleared, protected pages gated, Back button and other tabs handled); double-submit protection on OTP/feedback/password; all 60 internal links and 80 in-page anchors resolve; clean branded 404; no missing image alts; no uncaught JS errors on any of 240 page loads.

B. Website functionality map

Public / guest

- └ Home hero (popular-choice chips, destination autocomplete, dates, guests, "near me", map search), listing sections
- └ Search results list + map, sort (7), filters (price, rating, property type, amenities, popular, bed type), infinite scroll
- └ Property gallery, details, amenities, date picker, availability, price breakdown, [Book – disabled], host card, reviews, report
 - └ Reviews page
- └ Booking confirmation, receipt PDF
- └ Auth mobile OTP, email OTP, Google OAuth, OTP screen, OAuth callback, onboarding
- └ Support Help centre (6 guides), FAQ, Contact, Support/feedback hub, Report an issue, Safety
- └ Legal Terms, Privacy, Cookies, Cancellation & refunds, Shipping policy, About
 - └ Marketing Become a host, Refer

Signed-in guest

- └ Account profile, settings, password, login activity, profile verification (documents), Aadhaar KYC
- └ Wishlist, My memories (trips), selected add-ons, Chat
 - └ Session persistence, logout

Host

- └ Listing wizard (13 steps): method (AI / manual) → property type → stay type → location → address → capacity → amenities → add-ons → photos → details → pricing → discounts → cancellation policy → house rules
- └ AI import (processing / review / publish)
 - └ Dashboard: listings + manage, bookings (today/upcoming/past), calendar (+iCal), earnings, reviews, chat, account, settings (payouts, identity)

Platform / API (58 routes)

- └ auth, users, bookings (reserve / confirm / cancel / refund-preview), billing preview, search, hotels, wishlist, chat, reviews, feedback, KYC, host/*, uploads, Razorpay webhook

The complete row-by-row inventory (F001–F121) is in **Appendix 1**.

C. Test results

Test ID	Functionality	Test case	Result	Severity	Notes
TC001	Route smoke test	All 72 page routes + 8 extra URLs load at desktop 1440px (HTTP 200; 404 for unknown route)	PASS	—	80/80 OK, 0 uncaught page errors, 0 horizontal overflow
TC002	Route smoke test	Same 80 URLs at tablet 768px	FAIL	Low	79/80 OK; /property/[id]/reviews overflows horizontally (831px in 768px viewport) - BUG-021
TC003	Route smoke test	Same 80 URLs at mobile 390px	PASS	—	80/80 load, no page-level horizontal overflow (sign-in card clipping is inside a container - see BUG-007)
TC004	Link integrity	60 unique internal hrefs found across all pages return HTTP 200	PASS	—	No broken internal links
TC005	Link integrity	80 in-page #anchor links (Terms, Privacy, Cookies, Cancellation, Shipping, 6 Help guides, Become-a-host) resolve to an element	PASS	—	0 missing targets
TC006	Link integrity	External links (footer social icons)	FAIL	Low	Icons are deliberately non-interactive (code comment); look clickable under a "Get social" heading - UX-08
TC007	404 handling	Unknown route /this-route-does-not-exist	PASS	—	Branded 404 page + "Back to Home" (HTTP 404)
TC008	404 handling	Unknown property id /property/not-a-uuid	FAIL	Low	Shows "Property not found" but returns HTTP 200 (soft-404, bad for SEO) - BUG-029
TC009	Access control (UI)	29 protected /host/* pages while signed out	PASS	—	All show "Sign in to manage your hosting" (client-side gate); /chat, /onboarding, /otp*, /kyc redirect to /signin
TC010	Access control (UI)	Dev-only "Continue as demo host (dev)" login shortcut on host gate	PASS	—	Gated by NODE_ENV !== production; absent from production build and its client bundle
TC011	Build & static checks	<code>next build</code> (production)	PASS	—	Compiles; 72 pages + 58 API routes generated
TC012	Build & static checks	Unit tests (vitest)	PASS	—	41/41 pass (billing, refund, invoice, payout, aliases)
TC013	Build & static checks	TypeScript <code>tsc --noEmit</code>	PASS	—	No errors
TC014	Build & static checks	ESLint	PASS	—	0 errors, 101 warnings (mostly react-hooks set-state-in-effect / exhaustive-deps)
TC015	API: token verification	/api/bookings/reserve, /cancel, /cancel-with-refund, /refund-preview, /host/payout-methods, /auth/change-password, POST /users without Authorization	PASS	—	Return 401 before touching data
TC016	API: Razorpay webhook	POST without / with bad signature	PASS	—	Rejected (400) - signature verified; code review of confirm-payment also verifies HMAC
TC017	API: reserve validation	Code review of /api/bookings/reserve	PASS	—	Server recomputes price, validates dates (past/inverted/>90 nights), caps guests/add-ons
TC018	API: authorization	Chat / bookings / wishlist / users GET / login-events / host/* with only a client-supplied userId and NO token	FAIL	Critical	Requests proceed to the data layer (no 401) - BUG-001

Test ID	Functionality	Test case	Result	Severity	Notes
TC019	API: authorization	PATCH /api/users {action:deactivate-account update-profile} for arbitrary userId, no token	FAIL	Critical	Reaches service-role write + Auth ban path (500 only because test DB unreachable) - BUG-002
TC020	API: authorization	POST /api/kyc/aadhaar for arbitrary userId, no token	FAIL	High	Passes to service-role upsert; returns 200 {persisted:false} in test - BUG-003
TC021	API: input handling	Malformed JSON / non-multipart upload to JSON & upload endpoints	FAIL	Low	HTTP 500 with raw parser message instead of 400/415 - BUG-025
TC022	API: enumeration	POST /api/auth/check-email returns {exists:boolean} for any email, no rate limit	FAIL	Medium	Code review; account enumeration - BUG-014
TC023	Sign-in (mobile)	Empty number -> Send OTP	PASS	—	toasts=["Please enter a valid 10-digit mobile number"] apiCalls=0
TC024	Sign-in (mobile)	Letters typed into phone field	PASS	—	value after typing letters=""
TC025	Sign-in (mobile)	5-digit number rejected	PASS	—	toasts=["Please enter a valid 10-digit mobile number","Please enter a valid 10-digit mobile number"]
TC026	Sign-in (mobile)	Very long number (20 digits) boundary	PASS	—	accepted length=10, value="9876543210"
TC027	Sign-in (mobile)	Number starting with 1 (not a valid Indian mobile)	FAIL	Low	OTP API called 1x for 1234567890 - BUG-026
TC028	Sign-in (mobile)	Valid number + double-click Send OTP (dup submit)	PASS	—	OTP API called 1x; url=/otp?mode=phone
TC029	Sign-in (mobile)	Valid number navigates to OTP screen	PASS	—	/otp?mode=phone
TC030	Sign-in (mobile)	Server error while sending OTP shows message	PASS	—	toasts=["boom internal"]
TC031	Sign-in (mobile)	Network failure while sending OTP shows message	PASS	—	toasts=["Failed to fetch"]
TC032	Sign-in (email)	Empty email -> submit	PASS	—	["Please enter a valid email address"]
TC033	Sign-in (email)	Invalid email "plainaddress"	PASS	—	OTP API called 0x
TC034	Sign-in (email)	Invalid email "a@"	PASS	—	OTP API called 0x
TC035	Sign-in (email)	Invalid email "@b.com"	PASS	—	OTP API called 0x
TC036	Sign-in (email)	Invalid email "a@b"	PASS	—	OTP API called 0x
TC037	Sign-in (email)	Invalid email "a b@c.com"	PASS	—	OTP API called 0x
TC038	Sign-in redirect param	?redirect= https://evil.example then click close (X)	FAIL	High	landed on https://evil.example/phish - BUG-006
TC039	Sign-in mode toggle	Switch mobile->email keeps ?redirect	FAIL	Low	url=/signin?mode=email?redirect=%2Fwishlist - BUG-024
TC040	Sign-in responsive	Layout at 320px wide	FAIL	Medium	Card content clipped ~60px on the right (subtitle cut mid-word, phone input and "Send OTP" cropped) - BUG-007
TC041	Sign-in responsive	Layout at 360px wide	FAIL	Medium	Card content clipped ~60px on the right (subtitle cut mid-word, phone input and "Send OTP" cropped) - BUG-007
TC042	Sign-in responsive	Layout at 375px wide	FAIL	Medium	Card content clipped ~60px on the right (subtitle cut mid-word, phone input and "Send OTP" cropped) - BUG-007

Test ID	Functionality	Test case	Result	Severity	Notes
TC043	Sign-in responsive	Layout at 390px wide	FAIL	Medium	Card content clipped ~60px on the right (subtitle cut mid-word, phone input and "Send OTP" cropped) - BUG-007
TC044	Sign-in responsive	Layout at 414px wide	FAIL	Medium	Card content clipped ~60px on the right (subtitle cut mid-word, phone input and "Send OTP" cropped) - BUG-007
TC045	Sign-in responsive	Layout at 768px wide	PASS	—	no clipping
TC046	OTP screen	Renders 6 digit boxes after Send OTP	PASS	—	boxes=6
TC047	OTP screen	Verify disabled until 6 digits entered	PASS	—	disabled=true
TC048	OTP screen	Letter typed in OTP box	PASS	—	value=""
TC049	OTP screen	Typing 6 digits auto-advances across boxes	PASS	—	filled="123456"
TC050	OTP screen	Verify with unreachable auth backend shows error (no crash)	PASS	—	toasts=["Could not verify OTP. Please try again."] pageErrors=0
TC051	OTP screen	Resend control present	PASS	—	Resend is a countdown text ("resend code after 19 sec"), not a button - harness selector error corrected
TC052	OTP screen	Direct visit /otp?mode=phone with no stored number	PASS	—	→ /signin
TC053	Sort [mocked backend]	Select "Price: Low to high"	PASS	—	first=["Mock Stay 1","Mock Stay 2","Mock Stay 3"] refetched=false sortInPayload=no
TC054	Sort [mocked backend]	Select "Price: High to low"	FAIL	Medium	first=["Mock Stay 20","Mock Stay 19","Mock Stay 18"] refetched=false sortInPayload=no (expected first="Mock Stay 45" across all 45 results) - BUG-009
TC055	Sort [mocked backend]	Select "Top rated"	PASS	—	first=["Mock Stay 20","Mock Stay 19","Mock Stay 18"] refetched=false sortInPayload=no
TC056	Sort [mocked backend]	Select "Most reviewed"	PASS	—	first=["Mock Stay 7","Mock Stay 14","Mock Stay 6"] refetched=false sortInPayload=no
TC057	Sort [mocked backend]	Select "Newest listings"	PASS	—	first=["Mock Stay 1","Mock Stay 2","Mock Stay 3"] refetched=false sortInPayload=no
TC058	Sort [mocked backend]	Select "Best value"	PASS	—	first=["Mock Stay 1","Mock Stay 2","Mock Stay 3"] refetched=false sortInPayload=no
TC059	Filters	Clear all resets filters and refetches	PASS	—	requests 2->3; roomTypes=[]
TC060	Search states [mocked backend]	API 500 shows an error message + retry (not silent)	FAIL	Medium	Page shows "0 homestays found / No properties found - adjust your filters"; error is not surfaced - BUG-010
TC061	Search states [mocked backend]	Empty result set shows empty state	PASS	—	0 homestays found
TC062	Search states [mocked backend]	Loading skeleton shown while results load	PASS	—	skeleton nodes=48
TC063	Search persistence	Guest count survives refresh / shareable URL	PASS	—	guests before reload=1, after=1, url=/search?destination=Goa

Test ID	Functionality	Test case	Result	Severity	Notes
TC064	Property card	Click card opens property page	PASS	—	/property/1000
TC065	Filters [mocked backend]	Property type chips (House, Apartment, Guest House, Hotel, Cabin, Villa)	PASS	—	Sent as filters.roomTypes and trigger refetch
TC066	Filters [mocked backend]	Guest rating 4 / 5	PASS	—	Sent as filters.ratings
TC067	Filters [mocked backend]	Amenity chips that match catalogue (WiFi, Free Parking)	PASS	—	Resolved to amenity ids in payload
TC068	Filters [mocked backend]	Kitchen, AC, Heating, TV, Washing Machine, Swimming Pool	BLOCKED	—	Inconclusive: my mock amenity catalogue only had 3 names, so id resolution could not be observed
TC069	Filters [mocked backend]	Popular filters: Private room, Shared room, Free cancellation, Free breakfast*, Double bed, Couple friendly, Free wifi*, Family friendly	FAIL	Medium	Toggle highlights + refetches, but payload is identical and results do not change - BUG-008 (*may work via amenity match)
TC070	Filters [mocked backend]	Bed type chips (King, Queen, Single, Double)	FAIL	Medium	Not sent to API, no client-side effect - BUG-008
TC071	Price filter [mocked backend]	Dual range slider min/max handling incl. min>max	PASS	—	Display clamps ("₹ 5,000 - ₹ 100,000")
TC072	Search persistence [mocked backend]	Guests=2 set on results page; after reload/shared URL guests restored	FAIL	Medium	totalGuests before reload=2, after reload=1, url=/search?destination=Goa - BUG-020
TC073	Wishlist heart (signed out) [mocked backend]	Click heart on a result card while signed out	PASS	—	heartFound=1 url=/signin?redirect=%2Fproperty%2F1000 dialogs=0 toasts=["Sign in to save properties to your wishlist."]
TC074	Search results a11y	Icon-only buttons on result cards have accessible names	FAIL	Low	20 visible buttons without accessible name (likely wishlist hearts / carousel arrows) - BUG-027
TC075	FAQ	Accordion items present	PASS	—	items=14
TC076	FAQ	Expand item; opening another	PASS	—	first open=true; after opening 2nd: first=false, second=true
TC077	FAQ	Collapse item on second click	PASS	—	
TC078	Navbar	Currency menu opens with options	PASS	—	["INR · ₹", "USD · \$", "EUR · €", "GBP · £", "JPY · ¥", "AUD · A\$", "CAD · C\$", "SGD · S\$"]
TC079	Navbar	Selecting another currency updates label	PASS	—	Only the button LABEL changes ("USD."); prices stay in ₹ - see BUG-012
TC080	Navbar	Language menu opens	PASS	—	["English (US)", "Hindi", "हिन्दी", "Español", "Français"]
TC081	Navbar	"Sign In" -> /signin	PASS	—	/signin
TC082	Navbar	"New user" -> /signin (same destination as Sign In)	PASS	—	/signin (observation: no distinct sign-up path)
TC083	Navbar	"List your property" -> host flow	PASS	—	/host/list/method
TC084	Navbar	Logo -> home	PASS	—	
TC085	Home search	Search with empty destination	PASS	—	["Please enter a destination"] url=/
TC086	Search page	Reflected XSS via ?destination=	PASS	—	payload rendered as text, no dialog fired

Test ID	Functionality	Test case	Result	Severity	Notes
TC087	Mobile nav	Menu "Sign in" navigates to /signin	PASS	—	/signin
TC088	Mobile nav	Menu "List property" navigates to host flow	PASS	—	/host/list/method
TC089	Mobile nav	Label consistency: "List property" (mobile) vs "List your property" (desktop)	FAIL	Low	inconsistent CTA wording
TC090	Support hub	Card "Report an issue"	PASS	—	textarea=1 url=/support
TC091	Support hub	Card "Suggest improvement"	PASS	—	textarea=1 url=/support
TC092	Support hub	Card "Share experience"	PASS	—	textarea=1 url=/support
TC093	Support hub	Card "Referral"	PASS	—	textarea=1 url=/support
TC094	Support/Feedback form	Submit empty	PASS	—	["Please add a few details first."]
TC095	Support/Feedback form	Whitespace-only submit blocked	PASS	—	apiCalls=0
TC096	Support/Feedback form	Boundary: 1500 chars typed (limit 1000)	PASS	—	accepted=1000
TC097	Support/Feedback form	Double-click submit sends once	PASS	—	apiCalls=1
TC098	Support/Feedback form	Payload shape	PASS	—	{"userId":null,"type":"share_experience","description":"<script>alert(1)</script>Great "site" & more"}
TC099	Support/Feedback form	Success message shown	PASS	—	
TC100	Home hero	Popular choice chip toggles selected state	PASS	—	"5 ★" chip shows checked state (verified in screenshot) - harness detector was wrong
TC101	Home hero	Destination panel shows suggestions after typing [mocked /api/locations]	PASS	—	Suggestions render (Goa, Baga, Calangute, Anjuna, Panjim) - verified in screenshot
TC102	Language selector	Choose Hindi -> UI text changes	FAIL	Medium	Label changes to "Hindi" but no UI text is translated; no i18n library exists - BUG-012
TC103	Currency selector	Choose USD -> listing-card prices convert	FAIL	Medium	Header shows "\$ USD." but listing prices stay "₹ 1,717" - BUG-012
TC104	Currency selector	Selection persists after navigating to another page	FAIL	Low	Choice resets to INR on the next page (each page owns its own Navbar state)
TC105	Support/Feedback form	Server 500 shows error toast (text preserved)	PASS	—	["db down"] textarea kept="hello"
TC106	Change password	Empty fields -> Update	PASS	—	toasts=["Password must be at least 8 characters."] apiCalls=0
TC107	Change password	7-char password rejected (min 8)	PASS	—	toasts=["Password must be at least 8 characters.", "Password must be at least 8 characters."]
TC108	Change password	Mismatched confirmation rejected	PASS	—	toasts=["Passwords don't match.", "Password must be at least 8 characters.", "Password must be at least 8 characters."]
TC109	Change password	Weak all-numeric password "12345678" accepted (no complexity rule)	FAIL	Low	apiCalls=1

Test ID	Functionality	Test case	Result	Severity	Notes
TC110	Change password	Valid password, double-click -> single request	PASS	—	apiCalls=1
TC111	Change password	Success feedback	PASS	—	["Password updated.", "Password updated.", "Passwords don't match."]
TC112	Change password	Page promises password sign-in ("sign in with a password from now on") but no sign-in screen accepts a password	FAIL	Medium	signin, signin/email, signin/mobile show only OTP/Google; api.signInWithPassword() is unused by any screen - BUG-018
TC113	Profile form	Save with empty name	FAIL	Medium	Invalid value is sent to the API and no server-side value validation exists - BUG-017
TC114	Profile form	Save with 300-char name and age=-5	FAIL	Medium	Invalid value is sent to the API and no server-side value validation exists - BUG-017
TC115	Profile form	Age=999 out of range	FAIL	Low	Invalid value is sent to the API and no server-side value validation exists - BUG-017
TC116	Profile form	Phone = "abc"	FAIL	Low	phoneValue="+919876543210" sent={"action":"update-profile","userId":"11111111-1111-4111-8111-111111111111","patch":{"name":"Test Guest","email":" guest@example.com "},"phone
TC117	Profile form	Email = "not-an-email"	FAIL	Low	emailValue=" guest@example.com " sent={"action":"update-profile","userId":"11111111-1111-4111-8111-111111111111","patch":{"name":"Test Guest","email":"not-an-email","phone"
TC118	Account settings	"Personal information" row	PASS	—	-> /account/profile
TC119	Account settings	"Email & Phone no" row	PASS	—	-> /account/profile
TC120	Account settings	"Login activity" row	PASS	—	-> /account/login-activity
TC121	Account settings	"Profile verification" row	FAIL	Low	placeholder toast: ["Profile verification settings coming soon"] - BUG-023
TC122	Account settings	"Password & Security" row	PASS	—	-> /account/password
TC123	Account settings	"Language" row	FAIL	Low	placeholder toast: ["Language settings coming soon"] - BUG-023
TC124	Account settings	"Currency" row	FAIL	Low	placeholder toast: ["Currency settings coming soon"] - BUG-023
TC125	Account settings	"Reported issues" row	FAIL	Low	placeholder toast: ["Reported issues settings coming soon"] - BUG-023
TC126	Account settings	Delete Account opens confirmation (NOT confirmed)	PASS	—	
TC127	Account settings	Cancel closes confirmation, no request sent	PASS	—	
TC128	KYC Aadhaar form	Submit disabled on empty form	PASS	—	
TC129	KYC Aadhaar form	Letters in Aadhaar field ignored	PASS	—	value=""
TC130	KYC Aadhaar form	18 digits typed -> capped at 12 digits (+spaces)	PASS	—	value="1234 5678 9012"
TC131	KYC Aadhaar form	Upload .txt as Aadhaar photo is rejected	PASS	—	Client only sets accept=; server route rejects non-images ("Only JPG, PNG, WEBP") - verified in route code
TC132	KYC Aadhaar form	Upload 9MB image (limit 8MB) is rejected	PASS	—	["That photo is too large (max 8MB)."]

Test ID	Functionality	Test case	Result	Severity	Notes
TC133	KYC Aadhaar form	Submit stays disabled until consent ticked	PASS	—	
TC134	KYC Aadhaar form	Valid data + consent enables Submit	PASS	—	
TC135	KYC Aadhaar form	Invalid checksum number disables Submit	PASS	—	
TC136	Wizard: pricing	Weekday price = ""	PASS	—	nextDisabled=true guest price (before taxes) ₹0
TC137	Wizard: pricing	Weekday price = "0"	PASS	—	nextDisabled=true guest price (before taxes) ₹0
TC138	Wizard: pricing	Weekday price = "-500"	PASS	—	nextDisabled=true guest price (before taxes) ₹-570
TC139	Wizard: pricing	Weekday price = "1"	PASS	—	nextDisabled=false guest price (before taxes) ₹1
TC140	Wizard: pricing	Weekday price = "99999999"	PASS	—	nextDisabled=false guest price (before taxes) ₹11,39,99,999
TC141	Wizard: pricing	Weekday price = "1500.75"	PASS	—	nextDisabled=false guest price (before taxes) ₹1,711
TC142	Wizard: pricing	Absurd price ₹99,999,999/night is allowed with no upper bound or warning	FAIL	Low	nextDisabled=false - BUG-019
TC143	Wizard: discount	Percent field = "0"	PASS	—	field holds "0"; next disabled=false
TC144	Wizard: discount	Percent field = "-10"	FAIL	Medium	field holds "-10"; next disabled=false - BUG-019
TC145	Wizard: discount	Percent field = "100"	PASS	—	field holds "100"; next disabled=false
TC146	Wizard: discount	Percent field = "150"	FAIL	Medium	field holds "150"; next disabled=false - BUG-019
TC147	Wizard: details	Title 80 chars (limit 50)	PASS	—	accepted=50
TC148	Wizard: details	Description 700 chars (limit 500)	PASS	—	accepted=500
TC149	Wizard: details	Whitespace title + empty description blocks Next	PASS	Medium	disabled=true
TC150	Wizard: details	HTML in title is accepted as text (needs output-escaping check)	PASS	—	next disabled=false
TC151	Wizard: capacity	Decrement guests repeatedly bottoms out at a sane minimum	PASS	Medium	Max number of people 1 Bedrooms Private spaces for guests 2 Beds
TC152	Wizard: capacity	Increment guests 60x has an upper bound	PASS	—	Max number of people 61 Bedrooms Private spaces for guests 2 Beds
TC153	Wizard: house rules	Free-text check-in "banana" / check-out "25:99" accepted or rejected	FAIL	Medium	checkin="banana" checkout="25:99" nextDisabled=n/a - BUG-019
TC154	Session	Signed-in profile page shows account data	PASS	—	
TC155	Session	Session persists across reload	PASS	—	
TC156	Logout	Profile menu exposes "Sign out"	PASS	—	signOutCount=1
TC157	Logout	Sign out clears stored user id and tokens	PASS	—	{"uid":null,"tok":null,"refresh":null}; url=/signin
TC158	Session	UI treats a hand-edited localStorage user-id (no token) as signed in	FAIL	High	Client treats any stored user-id as signed in; combined with unauthenticated /api/users GET this is the client half of BUG-001
TC159	Session	Both tabs show account data before logout	PASS	—	
TC160	Logout	Protected page after logout shows sign-in prompt, not account data	PASS	—	/account/profile

Test ID	Functionality	Test case	Result	Severity	Notes
TC161	Logout	Browser Back after logout shows no account data	PASS	—	
TC162	Logout	Other open tab reflects sign-out without reload	PASS	—	synced
TC163	Logout	Other tab is signed out after reload	PASS	—	
TC164	Booking & payment	Date pick -> availability -> price breakdown on property page [mocked backend]	PASS	—	Works: ₹2,000 x 2 nights + GST 5% + fee 8% + GST 18% = ₹4,577.6
TC165	Booking & payment	Click Book / pay with Razorpay / confirmation	BLOCKED	—	NOT EXECUTABLE: BOOKING_DISABLED = true hard-coded; CTA reads "Bookings temporarily unavailable"
TC166	Booking & payment	Razorpay script fails to load	FAIL	Medium	Code review: rejection is treated as "user closed widget" - silent no-op - BUG-013 (latent while booking disabled)
TC167	Booking & payment	Payment succeeds but confirm-payment call fails	FAIL	High	Code review: toast "could not complete booking", status resets to bookable -> risk of double payment - BUG-015 (potential; webhook mitigates DB state)
TC168	Booking & payment	Money formatting in breakdown	FAIL	Low	Shows ₹57.6 and ₹4,577.6 (one decimal) - BUG-022
TC169	Session	Access-token refresh / 401 handling (code review)	FAIL	Medium	AuthContext handles only SIGNED_OUT; request() has no 401 handler - BUG-016 (potential, needs ~1h session to reproduce)
TC170	Reviews page	/property/[id]/reviews for missing/zero-review property	FAIL	High	Shows fabricated 4.9 / 417 reviews, fake "Bappi Lehri" cards, hard-coded rating bars - BUG-005
TC171	Reviews page	"Reserve" button on reviews page	FAIL	Medium	No click handler (dead control); "for 15 nights • 2 Adults" hard-coded - BUG-005
TC172	Booking confirmation	/booking-confirmation/<any id> signed out, or fetch fails	FAIL	High	Shows "Your Booking is Confirmed" with sample booking #10429 - BUG-004

D. Bugs

Status legend — **Reproduced**: observed in a browser or via a request to my local build. **Code-confirmed**: the logic is unambiguous in source but I could not trigger it live. **Potential**: plausible from code, not reproduced.

Evidence images are in `docs/qa-audit/`.

Critical

BUG-001 — Most API routes identify the caller from a client-supplied `userId`, not from the login token

- **Location**: `src/app/api/` — `chat`, `bookings` (GET/PATCH/POST), `bookings/details`, `wishlist`, `users` (GET), `auth/login-events`, `host/profile-info`, `host/reviews`, `host/listings/**`, `host/calendar/**`, `host/profile`, `reviews`, `feedback`, and the upload routes (`account/upload-photo`, `host/upload`, `kyc/aadhaar/upload`). Only 8 of 58 routes import `src/lib/auth-server.ts`, whose own doc-comment says a request `userId` must never be trusted.
- **Preconditions**: None (no account/login). The attacker needs a victim's user UUID (not treated as secret; e.g. exposed as chat/host identifiers).

- **Steps:**

1. With **no** Authorization header: GET /api/auth/login-events?userId=<uuid> · GET /api/host/profile-info?userId=<uuid> · GET /api/chat?userId=<uuid> · GET /api/bookings?userId=<uuid>&role=guest&label=upcoming .
2. POST /api/chat {"senderId":"<uuid>","recipientId":"<other>","text":"hi"} .

- **Expected:** 401 for a missing/invalid bearer token; identity derived from the verified token; ownership checked against that identity.
- **Actual:** Requests skip authentication and go to the data layer (I received DB-layer errors from my dead test DB — 500 / 404 — rather than 401 , proving the auth stage was passed). By code: login-events returns IPs/user-agents/timestamps for any user via the **service-role** client (bypasses RLS); profile-info returns any host's name, **email and phone** (service-role); wishlist and parts of bookings also use the service-role client; assertListingOwnedBy(listing, userId) (used by listing edit/toggle/photos/...) compares against the same spoofable id; upload and feedback endpoints accept anonymous calls (storage/table spam). chat reads, writes (senderId from the body) and deletes conversations by client-supplied ids through the **anon** client — so its real exposure depends on Supabase RLS policies I could not inspect (the server has no user session, so for chat to work at all the policies must admit anon access — an inference, unverified). Client side, isAuthenticated = Boolean(localStorage["hostiggo:user-id"]) , so the UI also treats any stored id as a session (see the log row "UI treats a hand-edited localStorage user-id as signed in"). A real host id ("the demo host has 150+ listings") is hard-coded at src/app/host/layout.tsx:10 ; I confirmed it is **not** in the production client bundle, but it gives anyone with repo access a known-valid target.
- **Severity:** Critical (security; PII exposure, impersonation). **Status:** Code-confirmed + request path reproduced. Not exploited on live data; RLS/WAF not verifiable from here.
- **Evidence:** log rows "API: authorization" (Section C); source references above.

BUG-002 — Anyone can deactivate (ban) or rewrite any account: PATCH /api/users

- **Location:** src/app/api/users/route.ts (PATCH), src/lib/services/admin-writes.ts (deactivateUserAccount , updateUserProfile). The POST handler in the same file *does* verify the token; PATCH does not.
- **Steps:** curl -X PATCH /api/users -H 'content-type: application/json' -d '{"action":"deactivate-account","userId":"<uuid>"}' — no auth header. Also {"action":"update-profile","userId":"<uuid>","patch":{"name":"...","email":"...","phone":"..."}} .
- **Expected:** 401 / 403 .
- **Actual:** Reached the service-role update (returned 500 only because my test DB was unreachable). In production this sets users.is_active=false and bans the user in Supabase Auth (~100-year ban_duration), permanently locking them out; update-profile rewrites name/email/phone.
- **Severity:** Critical. **Status:** Reproduced (request path) + code-confirmed. Destructive call was only made against the dead local DB.



High

BUG-003 — /api/kyc/aadhaar lets anyone overwrite any user's identity-verification record

- **Location:** src/app/api/kyc/aadhaar/route.ts .
- **Steps:** POST with a victim's userId , any name, a Verhoeff-valid 12-digit number, and arbitrary frontImagePath / backImagePath strings — no token.
- **Expected:** 401 ; user id from token; image paths restricted to that user's own uploads.

- **Actual:** Service-role `upsert(... onConflict: "user_id")` replaces name, hash, last-4 and image paths and resets status to `pending` . Paths are not validated, so a record can point at another user's stored document. Also returns `200 {persisted:false}` on any DB error (see BUG-011).
- **Severity:** High. **Status:** Code-confirmed; request reproduced (`200 {"data":{"persisted":false}}` against the dead DB).

BUG-004 — Booking-confirmation page shows a fake "Your Booking is Confirmed" for any id

- **Location:** `/booking-confirmation/[id]` — `src/app/booking-confirmation/[id]/page.tsx:128-145` .
- **Preconditions:** Signed out, **or** signed in with a failing/unauthorised booking lookup.
- **Steps:** Open `/booking-confirmation/999999` .
- **Expected:** Not-found, sign-in prompt, or an error.
- **Actual:** Renders hard-coded `SAMPLE_CONFIRMATION_B00KING` — "The Great Rooms Of Triply Homestay and services", Manali, booking #**10429**, ₹8,300, green "Your Booking is Confirmed" banner and a "Download Payment Receipt" button. A customer whose payment/lookup failed is told they are booked.
- **Severity:** High (false confirmation on a money flow). **Status:** Reproduced. **Evidence:** `docs/qa-audit/BUG-004-fake-confirmation.png` .

BUG-005 — Reviews page fabricates reviews, rating and counts

- **Location:** `/property/[id]/reviews` — `src/app/property/[id]/reviews/page.tsx:13-40,156-176,180-186` .
- **Steps:** Open `/property/<id>/reviews` for a property with no reviews, a failing API, or a non-existent id.
- **Expected:** Real reviews, or an empty state ("No reviews yet").
- **Actual:** Shows **4.9 ★ (417)**, three identical "Bappi Lehri — 3 weeks ago" cards (`SAMPLE_REVIEWS`), hard-coded 72/65/15/10/5 % rating bars, a "Reserve ₹2,349 · for 15 nights · 2 Adults" bar, and a **"Reserve" button with no click handler**. Fabricated reviews shown to shoppers is also a consumer-protection risk.
- **Severity:** High. **Status:** Reproduced. **Evidence:** `docs/qa-audit/BUG-005-fake-reviews-tablet.png` (also shows BUG-021).

BUG-006 — Open redirect through the `redirect` query parameter

- **Location:** `src/components/features/FigmaAuthScreen.tsx:91,418,490` ; `src/app/kyc/aadhaar/page.tsx:104` .
- **Steps:** Open `/signin?redirect=https://evil.example/phish` , click the ✕ (close) button. After a successful login the same value is used (`router.push(redirect || ...)`).
- **Expected:** Only same-origin relative paths (single leading `/` , not `//`) are honoured.
- **Actual:** Browser navigates to `https://evil.example/phish` . A phishing link on the real domain can bounce users off-site after they authenticate.
- **Severity:** High. **Status:** Reproduced (close button); post-login path code-confirmed.

● Medium

BUG-007 — Mobile sign-in card is clipped on every phone width (320–414 px)

- **Location:** `/signin` , `/signin/mobile` , `/signin/email` (`FigmaAuthScreen`).
- **Steps:** Open `/signin` at 320, 360, 375, 390 or 414 px wide.

- **Expected:** Card content fits the viewport.
- **Actual:** Content is ~60 px wider than the card: the subtitle is cut mid-word ("...travel plans m"), the phone input runs past the card edge and the "Send OTP" button is cropped. Fine at 768 px. The flow still works, hence Medium.
- **Status:** Reproduced. **Evidence:** docs/qa-audit/BUG-007-signin-360.png .

BUG-008 — Many search filters do nothing

- **Location:** Search sidebar `FiltersSidebar.tsx` ; `api.searchByState` (`src/lib/api.ts` ~L545-570); home hero chips.
- **Steps:** [mocked backend] On `/search?destination=Goa` toggle *Private room*, *Shared room*, *Free cancellation*, *Couple friendly*, *Family friendly*, *Double bed*, *King/Queen/Single bed*, or the home chips *Free cancellation* / *Family comfort*.
- **Expected:** Results are narrowed.
- **Actual:** The chip highlights and a refetch happens, but the request payload is **identical** (`amenities:[]` , `roomTypes:[]`) and no client-side filtering occurs — the payload builder never sends `stayTypes` , `freeCancellation` , `coupleFriendly` , `familyFriendly` or `bedTypes` . The old server-side `stayTypes` handling in `src/app/api/search/route.ts` is shadowed by the rewrite to the external Go service (`next.config.js`). *Property type, rating, price and matched-amenity filters do work*.
- **Status:** Reproduced (payload inspection) + code-confirmed.

BUG-009 — Sorting only re-orders the results already loaded

- **Steps:** [mocked backend] 45 results (page size 20) → *Sort By: Price: High to low*.
- **Expected:** Highest-priced of **all** results first (server-side sort, then paginate).
- **Actual:** No request is made and no sort parameter exists; the first 20 are re-ordered, so "Stay 20" appears first though "Stay 45" is the most expensive. Any user sorting a multi-page result set sees wrong top results. *Newest listings* and *Best value* produced no visible re-ordering with my fixture (inconclusive).
- **Status:** Reproduced.

BUG-010 — A search-API failure is presented as "No properties found"

- **Steps:** [mocked backend] Make `POST /api/search` return 500 and open `/search?destination=Goa` .
- **Expected:** An error message with retry.
- **Actual:** **"0 homestays found** — No properties found. Try adjusting your filters...". The context stores an `error` but the UI never shows it. (The home page, by contrast, does show a proper "couldn't load stays" message.)
- **Status:** Reproduced. **Evidence:** docs/qa-audit/BUG-010-search-error-as-empty.png .

BUG-011 — KYC reports success when nothing was saved; verification status lives only in the browser

- **Location:** `src/app/api/kyc/aadhaar/route.ts` (returns `200 {persisted:false}` on error) and `src/app/kyc/aadhaar/page.tsx:172-197` (checks only `res.ok`); `src/lib/aadhaar.ts` (`hasSubmittedAadhaarKyc` reads `localStorage`).
- **Steps:** Submit KYC while the DB write fails.
- **Expected:** An error; status read from the server.

- **Actual:** Toast "Aadhaar details received — verification is in progress", `submitted` flag set in `localStorage`, the host is never prompted again — with no record saved. On another device/cleared storage the host is re-prompted.
- **Status:** Reproduced server half (`HTTP 200 {"persisted": false}`); client half code-confirmed.

BUG-012 — Currency and language selectors are cosmetic

- **Location:** `Navbar.tsx` (`useState("INR")` , `useState("English")`); no `i18n` or `FX` code anywhere.
- **Steps:** Choose *USD* or *Hindi* in the header.
- **Expected:** Prices convert / text translates; choice persists.
- **Actual:** Only the button label changes (`$ USD.` , `Hindi`); listing prices stay `₹` , no text is translated, and the choice resets to `INR/English` on the next page (each page mounts its own `Navbar`). `Settings` → `Language/Currency` are "coming soon".
- **Status:** Reproduced.

BUG-013 — If the Razorpay script fails to load, "Book" silently does nothing

- **Location:** `property/[id]/page.tsx:1068-1090` , `razorpayCheckout.ts` .
- **Actual:** A script-load failure rejects `openRazorpayCheckout` ; the catch assumes "guest closed the widget" and just resets state — no message. Ad-blockers/CSP/network issues produce a dead button. **Latent** while `BOOKING_DISABLED` is on.
- **Status:** Code-confirmed (UI path currently unreachable).

BUG-014 — Account enumeration, no rate limiting

- **Location:** `POST /api/auth/check-email` returns `{exists: boolean}` for any email via the service-role client.
- **Status:** Code-confirmed (the route returns 400 for an empty body in my probe; the `exists` branch needs a live DB).

BUG-017 — Profile and account forms have no value validation (client or server)

- **Steps:** [mocked backend] `/account/profile` → save with empty name / 300-char name / age `-5` / age `999` / phone `abc` / email `not-an-email` .
- **Expected:** Field errors; server rejects.
- **Actual:** Every value is POSTed to `PATCH /api/users update-profile` ; `updateUserProfile` only allow-lists column names and does not validate values, so junk is written to `users` . (The email edit also changes the profile email without touching the auth email.)
- **Status:** Reproduced (payloads) + code-confirmed.

BUG-018 — "Password & Security" promises a sign-in method that doesn't exist

- **Actual:** The page says setting a password lets you "sign in with a password from now on", but the sign-in screens only offer OTP and Google; `api.signInWithPassword` is not used by any screen. Users can set a password they can never use (there's also no password-reset path).
- **Status:** Reproduced (UI text vs. sign-in screens) + `grep`.

BUG-019 — Host wizard accepts invalid values that are rejected only later (or never)

- **Steps:** [mocked backend] *Discount step:* enter `-10` or `150` (%) · *Capacity:* press "+" repeatedly · *House rules:* type `banana` / `25:99` as check-in/out.
- **Actual:** All accepted with **Next** enabled. The discounts service later throws "between 0 and 100" (so the host discovers it at publish, not in the field); guests can be set to 61+; check-in/out times are free text and shown to guests as typed. Price has no upper bound (₹99,999,999/night allowed).
- **Status:** Reproduced.

BUG-020 — Search dates and guests are not in the URL

- **Steps:** [mocked backend] On `/search?destination=Goa` set adults to 2 → reload.
- **Expected:** State restored (the README advertises "Search persistence via URL parameters").
- **Actual:** Guests revert to 1 (only `destination` is in the URL). Refresh or a shared link loses dates and guests.
- **Status:** Reproduced.

◆ Potential (not reproduced)

BUG-015 — Paid but told the booking failed → risk of paying twice (High, potential)

`property/[id]/page.tsx:1094-1110` : if `confirm-payment` fails after Razorpay success (timeout/500/closed tab), the user sees "Could not complete the booking" and the Book button becomes available again. The webhook can still finalize server-side, but the UI gives no "you were charged" guidance. Unreachable while booking is disabled; recommend fixing before re-enabling.

BUG-016 — Access token is never refreshed (Medium, potential)

`request()` sends the token stored at login; `AuthContext` handles only `SIGNED_OUT`, not `TOKEN_REFRESHED`, and there is no 401 handling. After the ~1 h token lifetime, calls to token-verified routes (reserve, cancel, payout methods, change-password) will return `401 "Please sign in again"` while the UI still looks signed in.

○ Low

ID	Title	Location / detail	Status
BUG-021	Horizontal overflow at tablet width	<code>/property/[id]/reviews</code> at 768 px: page is 831 px wide; third card clipped	Reproduced
BUG-022	Money shown with one decimal	Price breakdown: <code>₹57.6</code> , <code>₹4,577.6</code> (should be <code>₹57.60</code> , <code>₹4,577.60</code>)	Reproduced
BUG-023	"Coming soon" placeholder rows in Settings	<i>Profile verification, Language, Currency, Reported issues</i> — although <code>/account/verification</code> exists	Reproduced
BUG-024	Malformed URL on sign-in mode switch	<code>/signin?mode=email?redirect=%2Fwishlist</code> (second ?), <code>FigmaAuthScreen.tsx:468</code>	Reproduced

ID	Title	Location / detail	Status
BUG-025	Bad input returns HTTP 500 and leaks parser text	Malformed JSON → 500 Expected property name or '}' in JSON...; non-multipart upload → 500; confirm-payment / reserve echo code / details	Reproduced
BUG-026	Invalid Indian mobile numbers accepted	1234567890 triggers an OTP request (only length ≥ 10 is checked)	Reproduced
BUG-027	Icon-only controls without accessible names	/search : 20 unnamed buttons + 2 unlabeled range inputs; /report-issue : 3 unlabeled inputs; 2 unnamed header buttons when signed in	Reproduced
BUG-028	"Report an issue" only opens a mailto:	No in-app submission/confirmation; does nothing without a mail client (the Support → Feedback form does POST to /api/feedback)	Reproduced
BUG-029	Unknown property returns HTTP 200	/property/not-a-uuid shows "Property not found" with 200 (soft-404)	Reproduced

Observations (not counted as bugs)

- **OBS-01 — Bookings disabled site-wide.** BOOKING_DISABLED = true (property/[id]/page.tsx:91 , commit "Temporarily disable booking site-wide"). The CTA reads "Bookings temporarily unavailable"; the flag is **client-only** — /api/bookings/reserve still opens Razorpay orders for authenticated callers.
- **OBS-02 — Dev-server memory.** next dev grew to ~13 GB RSS and was OOM-killed twice while compiling routes under load; production build ran at ~110–330 MB. Not seen in production mode; possibly worth a look.
- **OBS-03 — Hardening gaps.** No Content-Security-Policy , X-Frame-Options / frame-ancestors , Referrer-Policy or Permissions-Policy headers; X-Powered-By: Next.js exposed; no sitemap.xml .
- **OBS-04 — Timezone edge.** /api/bookings/reserve compares against new Date().toISOString() (UTC), so between 00:00–05:30 IST a start date of "yesterday" passes the not-in-the-past check.
- **OBS-05 — Tokens in localStorage .** Access/refresh tokens are readable by any XSS. No XSS was found (reflected-XSS probe on ?destination= escaped correctly).
- **OBS-06 — Build-time data.** The home page is pre-rendered at build; if Supabase is unreachable during the build it is baked with no listings until revalidation (s-maxage=60).

E. UX issues (usability, not functional defects)

ID	Issue
UX-01	The site-wide booking freeze is only revealed after the user picks dates, checks availability and sees a price; the sticky "Reserve" is greyed with no explanation. Tell users up front.
UX-02	"Sign In" and "New user" open the same screen; the second label implies a different flow.
UX-03	Grammar: "1 Adults • 1 Room" in the guest summary.
UX-04	Repeated clicks stack identical toasts (e.g. "Password must be at least 8 characters." ×2–3).
UX-05	Signed-out wishlist still shows "All saved ▼ + Edit" controls beside the sign-in prompt.

ID	Issue
UX-06	Inconsistent CTA wording: "List property" (mobile menu) vs "List your property" (desktop).
UX-07	Password rule is length-only (<code>12345678</code> accepted).
UX-08	Footer social icons look clickable but are inert (by design, but under a "Get social" heading).
UX-09	<i>Become a host</i> shows a sample host ("Rahul Kumar", ₹42,800/month) with no "example" label.
UX-10	Wizard price step shows a guest price of ₹-570 when a negative number is typed; property-type step shows a search box labelled "(coming soon)".
UX-11	30+ pages share the default <code><title></code> ("Hostiggo - Find Your Perfect Stay") and property pages are client-rendered (<code>'use client'</code> + <code>useEffect</code> fetch), so listings have no unique title/meta for search engines or link previews.
UX-12	After tapping the heart while signed out, sign-in returns the user to the <i>property</i> page instead of the search results they were browsing.

F. Responsive issues

Viewport	Finding
Mobile 320–414 px	Sign-in card clipped ~60 px (BUG-007). Home, Search (filters collapse to "More Filters", "Show Map" pill), Wishlist, Become-a-host, hamburger menu all render correctly. 80/80 URLs load with no page-level horizontal scroll.
Tablet 768 px	<code>/property/[id]/reviews</code> overflows horizontally (831 > 768, BUG-021). Otherwise 79/80 clean; header wraps ("Sign In" on two lines) but stays usable.
Desktop 1440 px	80/80 clean.
Not covered	Authenticated screens (wizard, host dashboard, account) were only loaded at desktop with a mocked session; at tablet/mobile the crawl saw their signed-out gate only. Real touch gestures (swipe carousels, pinch-zoom on maps) were not tested.

G. Blocked / not tested

Area	Reason
Any live-data behaviour (real listings, real search, reviews, wishlists, chat, bookings, host dashboards, payouts, earnings, iCal calendar)	Sandbox egress policy blocks Supabase/search service (403); no credentials. To unblock: in the cloud environment settings add <code>jhihqmkqvbwfniwculhk.supabase.co</code> and <code>search-service-backend.vercel.app</code> to allowed domains and provide a test Supabase project (not production).
OTP / email delivery, Google sign-in	External providers; would send real SMS/email to real people
Razorpay checkout, refunds, cancellation-with-refund, receipt PDF	<code>BOOKING_DISABLED</code> , no keys, financial transactions (Not Executed — Requires Authorization)
Google Maps (map view, location step, "near me")	Maps API blocked / no key; geolocation prompt

Area	Reason
Account deactivation confirm, listing publish, message sending, cancel booking	Destructive / affects real data (Not Executed — Requires Authorization)
Photo/document uploads end-to-end	Writes to production storage (validation logic reviewed in code)
AI import ("List with AI")	<code>AI_LISTER_URL</code> not configured
Error boundaries (<code>error.tsx</code> , <code>global-error.tsx</code>)	Could not trigger a render error safely
Performance	No meaningful timing possible (network blocked, dev/prod on localhost). I make no performance claims; only OBS-02.
Cross-browser (Firefox/Safari), real devices, screen readers	Only headless Chromium available; a11y checked with an automated scan only

H. Recommendations (based only on what was observed)

Do now (security)

1. Make `getAuthenticatedUserId()` the **default** for every non-public route and derive identity from it; remove `userId` / `senderId` / `hostId` from request bodies/queries as an identity source. Start with `PATCH /api/users` , `/api/kyc/aadhaar` , `/api/chat` , `/api/auth/login-events` , `/api/host/**` , `uploads` , `/api/bookings*` , `/api/wishlist` . Consider a shared wrapper so a new route can't forget it, and enable/verify RLS as defence in depth. Add a test that every route returns 401 without a token.
2. Restrict `redirect` to same-origin relative paths (`^(?!/)`), everywhere it is read.
3. Validate KYC image paths against the caller's own folder; make `persisted:false` an error (non-200) and store KYC status server-side.
4. Rate-limit `check-email` , OTP and feedback; stop echoing `code` / `details` / `parser` messages in 500s.
5. Add CSP, `frame-ancestors` / `X-Frame-Options` , `Referrer-Policy` ; set `poweredByHeader: false` .

Do before re-enabling bookings

6. Delete the sample-data fallbacks in `booking-confirmation` and `reviews` ; render not-found/sign-in/empty states instead (BUG-004/005).
7. Handle Razorpay script-load failure and confirm-payment failure explicitly ("if you were charged, don't pay again — reference ..."), and enforce the booking kill-switch server-side (BUG-013/015, OBS-01).
8. Refresh/sync the access token (`TOKEN_REFRESHED`) and handle 401 by re-authenticating (BUG-016).

Search quality

9. Send `stayTypes` , `freeCancellation` , `coupleFriendly` , `familyFriendly` , `bedTypes` and a `sort` field to the search service (or hide the controls until supported); surface search errors; put destination, dates, guests and filters in the URL (BUG-008/009/010/020).

Forms & polish

10. Add value validation on `updateUserProfile` and in the profile form; validate discount % (0–100), capacity, times (BUG-017/019); fix mobile sign-in width (BUG-007); either implement or hide currency/language and the "coming soon" rows; remove or build password sign-in (BUG-012/018/023).
11. Give listings unique `<title>` /meta (server-render `generateMetadata`), add `sitemap.xml` ; add `aria-label` s to icon buttons and sliders (BUG-027).

Appendix 1 — Functionality inventory

ID	Page / section	Functionality	User action	Expected	Actual	Status
F001	Navbar	Logo	Click logo	Go to home	Goes to /	PASS
F002	Navbar	Currency selector - open	Click "INR."	Menu of currencies	17 currencies listed	PASS
F003	Navbar	Currency selector - apply	Choose USD	Prices convert	Only label changes; prices stay ₹; resets on next page (BUG-012)	FAIL
F004	Navbar	Language selector - open	Click "English"	Menu of languages	English/Hindi/Español/Français... listed	PASS
F005	Navbar	Language selector - apply	Choose Hindi	UI translated	Label only; nothing translated (BUG-012)	FAIL
F006	Navbar	Sign In	Click Sign In	Open sign-in	/signin	PASS
F007	Navbar	New user	Click New user	Open sign-up	/signin (identical to Sign In - passwordless)	PASS
F008	Navbar	List your property	Click	Start host flow	/host/list/method	PASS
F009	Navbar (mobile)	Hamburger menu	Tap ☰	Menu with Sign in / New user / List property	Works; label "List property" differs from desktop (UX-06)	PASS
F010	Navbar (signed in)	Profile menu -> Sign out	Open menu, Sign out	Session cleared, go to /signin	Storage cleared, /signin	PASS
F011	Navbar (signed in)	Profile menu links (Chat, Wishlist, Profile, Hosting)	Click each	Navigate	Not exercised (hrefs seen in code only)	NOT TESTED
F012	Footer	Company/Hosting/Support/Legal links (~28)	Click each	Open page	All 60 unique internal links return 200	PASS
F013	Footer	Download App (Android/iOS)	Click	Disabled "Soon" label	Non-interactive "Soon" badges	PASS
F014	Footer	Social icons	Click	Open profile	Non-interactive by design; look clickable (UX-08)	FAIL
F015	Footer	Footer "English" button	Click	Language menu	Not verified (click-all data discarded)	NOT TESTED
F016	Home hero	Popular-choice chips	Click chip	Toggle selected	Checked state shown (5 ★ verified)	PASS
F017	Home hero	Chips "Free cancellation", "Family comfort"	Select then search	Filter results	Set in UI state but never sent to search (BUG-008)	FAIL
F018	Home hero	Destination box + suggestions	Type "Goa"	Suggestions	Goa, Baga, Calangute, Anjuna, Panjim	PASS
F019	Home hero	Search with empty destination	Click Search	Validation message	Toast "Please enter a destination"	PASS
F020	Home hero	Search with XSS string	Type , search	No script execution	Rendered as text, no dialog	PASS
F021	Home hero	Guests dropdown (+/-/Done)	Change counts	Counts update within limits	Works (limits 1-16 adults etc. in code)	PASS
F022	Home hero	Check-in / Check-out picker	Open, pick range	Dates set	Verified on property page picker; home instance same component	PASS

ID	Page / section	Functionality	User action	Expected	Actual	Status
F023	Home hero	"Use my location" / "Search on Map"	Click	Geo search / map view	Needs geolocation + Google Maps (blocked)	NOT TESTED
F024	Home	Listing sections / popular stays	Load home	Show stays	Backend blocked: error state "couldn't load stays" shown correctly; content not verifiable	NOT TESTED
F025	Search	Results list + count	Open /search? destination=Goa	List + "N homestays found"	45 found, 20 rendered [mocked]	PASS
F026	Search	Infinite scroll	Scroll	Next page via cursor	20 → 40, cursor sent [mocked]	PASS
F027	Search	Sort menu options	Open Sort By	7 options	Recommended, Price ↑/↓, Top rated, Most reviewed, Newest, Best value	PASS
F028	Search	Sort correctness	Price: High to low with >1 page	Highest price of ALL results first	Sorts only loaded page; no refetch (BUG-009)	FAIL
F029	Search	Property-type filter	Toggle House/Villa/...	Filter results	Sent as roomTypes	PASS
F030	Search	Guest-rating filter (3/4/5)	Click	Filter results	Sent as ratings	PASS
F031	Search	Amenity filters	Toggle WiFi/Parking	Filter results	Sent as amenity ids (when catalogue matches)	PASS
F032	Search	Popular filters (Private/Shared room, Free cancel., Couple/Family friendly)	Toggle	Filter results	Highlight only; payload unchanged (BUG-008)	FAIL
F033	Search	Bed-type filters	Toggle	Filter results	Not sent; no effect (BUG-008)	FAIL
F034	Search	Price range slider	Drag / set	Filter by price	minPrice/maxPrice sent; min>max clamps	PASS
F035	Search	Clear all	Click	Reset filters + refetch	Works	PASS
F036	Search	Empty state	0 results	Message + Clear filters	Shown	PASS
F037	Search	API failure state	Search API 500	Error + retry	Shows "0 homestays / No properties found" (BUG-010)	FAIL
F038	Search	Loading skeleton	Slow API	Skeleton	Skeleton shown	PASS
F039	Search	State in URL (dates/guests)	Set guests=2, reload	Restored	Resets to 1 (BUG-020)	FAIL
F040	Search	Result card click	Click card	Open property	/property/<id>	PASS
F041	Search	Wishlist heart (signed out)	Click heart	Prompt sign-in	Toast + /signin (returns to property, not search)	PASS
F042	Search	Show Map / map view	Click Show Map	Map with markers	Google Maps blocked in sandbox	NOT TESTED
F043	Search	Reflected XSS via ?destination=	Load with payload	Escaped	Escaped	PASS
F044	Property	Property detail load	Open /property/1000	Details	Renders [mocked]; unknown id = "Property not found" with HTTP 200 (BUG-029)	PASS
F045	Property	Date-range picker	Select Dates → pick	Dates shown, nights computed	Works (Oct 13-15 → 2 nights)	PASS

ID	Page / section	Functionality	User action	Expected	Actual	Status
F046	Property	Check availability	Click	Available / reason	Works [mocked]	PASS
F047	Property	Price breakdown	After dates	Itemised total	Correct arithmetic; 1-decimal money formatting (BUG-022)	FAIL
F048	Property	Book / Reserve / Razorpay checkout	Click Book	Pay and confirm	Disabled site-wide: BOOKING_DISABLED=true - "Bookings temporarily unavailable"	NOT TESTED
F049	Property	Gallery "Show all photos", Share, Save	Click	Open gallery / copy link / save	Not exercised	NOT TESTED
F050	Property	Contact host / Message host	Click	Chat or sign-in	Not exercised	NOT TESTED
F051	Property	Submit review form	Submit	Only eligible guests can review	Not exercised (backend)	NOT TESTED
F052	Property reviews	Reviews page content	Open /property/<id>/reviews	Real reviews or empty state	Fabricated 4.9 / 417 reviews (BUG-005)	FAIL
F053	Property reviews	"Reserve" button	Click	Start booking	No handler; hard-coded "15 nights • 2 Adults" (BUG-005)	FAIL
F054	Booking confirmation	Confirmation page	Open with any id / signed out	404 or real booking	Fake confirmed booking #10429 (BUG-004)	FAIL
F055	Booking confirmation	Download payment receipt (PDF)	Click	PDF of real booking	Not exercised	NOT TESTED
F056	Sign-in (mobile)	Empty / short number	Click Send OTP	Validation	Toast "valid 10-digit number"	PASS
F057	Sign-in (mobile)	Letters / 20 digits in field	Type	Blocked / capped	Letters rejected, capped at 10 digits	PASS
F058	Sign-in (mobile)	Invalid Indian prefix (1234567890)	Send OTP	Rejected	Request sent (BUG-026)	FAIL
F059	Sign-in (mobile)	Double click Send OTP	dblclick	One request	1 request	PASS
F060	Sign-in (mobile)	Server / network error	Force 500 / abort	Message	Toast shown	PASS
F061	Sign-in (mobile)	Phone-width layout ≤414px	View on phone	Card fits	Clipped ~60px (BUG-007)	FAIL
F062	OTP	6-box entry / auto-advance / verify gating	Type code	Works	Works; verify disabled until 6 digits	PASS
F063	OTP	Resend countdown	Wait	Resend after 30 s	Countdown text shown; resend action not executed	NOT TESTED

ID	Page / section	Functionality	User action	Expected	Actual	Status
F064	OTP	Verify OTP against real auth	Enter code	Sign in	No live backend	NOT TESTED
F065	OTP	Direct visit without state	Open /otp?mode=phone	Redirect to /signin	Redirects	PASS
F066	Sign-in (email)	Empty and malformed emails	Submit	Validation	Rejected: empty, plainaddress, a@, @b.com, a@b, a b@c.com	PASS
F067	Sign-in (email)	Email OTP delivery	Submit valid email	Email sent	No live backend / would send real email	NOT TESTED
F068	Sign-in	Continue with Google	Click	OAuth	External OAuth not available	NOT TESTED
F069	Sign-in	?redirect= handling	Close (X) with external URL	Same-origin only	Navigates to external site (BUG-006)	FAIL
F070	Sign-in	Mode toggle keeps redirect	Switch to email	Valid URL	"?mode=email?redirect=" malformed (BUG-024)	FAIL
F071	Auth	OAuth callback with no params	Open /auth/callback	Redirect with error	→ /signin?error=no_oauth_response	PASS
F072	Auth	Password login / forgot / reset	n/a	n/a	No such UI - product is passwordless (but see BUG-018)	NOT TESTED
F073	Session	Persistence across reload	Reload	Still signed in	Yes	PASS
F074	Session	Logout → protected page, Back, other tab	Sign out then navigate	No account data	Correct in all three	PASS
F075	Session	Token refresh / expiry	Wait >1 h	Silent refresh or re-login	Not refreshed (BUG-016, potential)	FAIL
F076	Account	Profile view	Open /account/profile	Details	Shows name/email/phone	PASS
F077	Account	Profile edit validation	Save invalid values	Rejected	Empty name, age -5/999, phone "abc", bad email all sent (BUG-017)	FAIL
F078	Account	Profile photo upload	Upload	Photo saved	Not executed (writes storage)	NOT TESTED
F079	Account	Change password	Empty/short/mismatch/valid	Validation + success	Works; no complexity rule (UX-07)	PASS
F080	Account	Password & Security wording	Read page	Feature usable	Promises password sign-in that does not exist (BUG-018)	FAIL
F081	Account	Settings rows	Click each	Open setting	4 rows show "coming soon" (BUG-023)	FAIL
F082	Account	Notification toggles	Toggle	Persist	Not executed	NOT TESTED
F083	Account	Delete account dialog	Open then Cancel	Confirm dialog; cancel is safe	Works; no request sent on cancel	PASS
F084	Account	Delete account (confirm)	Confirm	Deactivate	NOT EXECUTED - requires authorization	NOT TESTED

ID	Page / section	Functionality	User action	Expected	Actual	Status
F085	Account	Login activity / Verification documents modal	Open	List / upload	Not exercised (backend)	NOT TESTED
F086	KYC	Aadhaar form validation	Fill invalid/valid	Verhoeff checksum, gating	Correct; submit gated on all fields + consent	PASS
F087	KYC	Photo size limit	Upload 9 MB	Rejected	Toast "max 8MB"	PASS
F088	KYC	Submission persistence / status	Submit with failing DB	Error	Shows success; status stored only in localStorage (BUG-011)	FAIL
F089	Wishlist	Signed-out state	Open /wishlist	Sign-in prompt	Shown	PASS
F090	Wishlist	Create / rename / delete lists	Use UI	CRUD	Not exercised (backend)	NOT TESTED
F091	My Memories	Tabs + empty state	Open	Upcoming/Completed/Canceled	Render, empty state OK [mocked]	PASS
F092	My Memories	Cancel booking / refund	Cancel	Refund per policy	NOT EXECUTED - destructive / needs payment	NOT TESTED
F093	Chat	Chat list empty state + auth gate	Open /chat	Gate or empty state	Signed out → /signin; empty state OK	PASS
F094	Chat	Send / receive / delete messages	Use UI	Messaging	Not exercised (would message real users)	NOT TESTED
F095	Support	Support hub cards	Click each of 4	Form opens	All open a textarea form	PASS
F096	Support	Feedback form	Empty / spaces / 1500 chars / dblclick / 500	Validation & feedback	All correct (limit 1000, 1 request, error toast)	PASS
F097	Support	Report an issue	Send	Ticket created	Only opens a mailto: (BUG-028)	FAIL
F098	Support	FAQ accordion	Expand/collapse	Works	14 items; single-open behaviour	PASS
F099	Support	Contact page	mailto / tel links	Open mail/dial	Links present (not clicked)	PASS
F100	Help / legal	6 help guides, Terms, Privacy, Cookies, Cancellation, Shipping, Safety, About	Open + use TOC	Render; anchors work	All render; 80/80 anchors resolve	PASS
F101	Become a host	Landing page	Open, tap CTAs	Marketing + CTA to wizard	Renders; "Get Started" not clicked; sample earnings card is illustrative (UX-09)	PASS
F102	Referral	/refer and /refer/dashboard	Open	Page / dashboard	Renders; dashboard silently redirects to /refer (signed out)	PASS
F103	Host area	Signed-out gate on 29 host pages	Open	Sign-in prompt	Shown ("Sign in to manage your hosting")	PASS
F104	Host wizard	13 steps render + KYC prompt for new hosts	Walk steps	Steps in order	All render; /host/list/verification redirects to house-rules	PASS
F105	Host wizard	Pricing step	0, -500, huge, decimals	Bounded	Blocks ≤0; no upper bound (UX-10)	PASS
F106	Host wizard	Discount step	-10 / 150 %	Rejected	Accepted client-side (BUG-019)	FAIL
F107	Host wizard	Capacity step	Min/max	Bounded	Min 1 OK; guests to 61+ (BUG-019)	FAIL

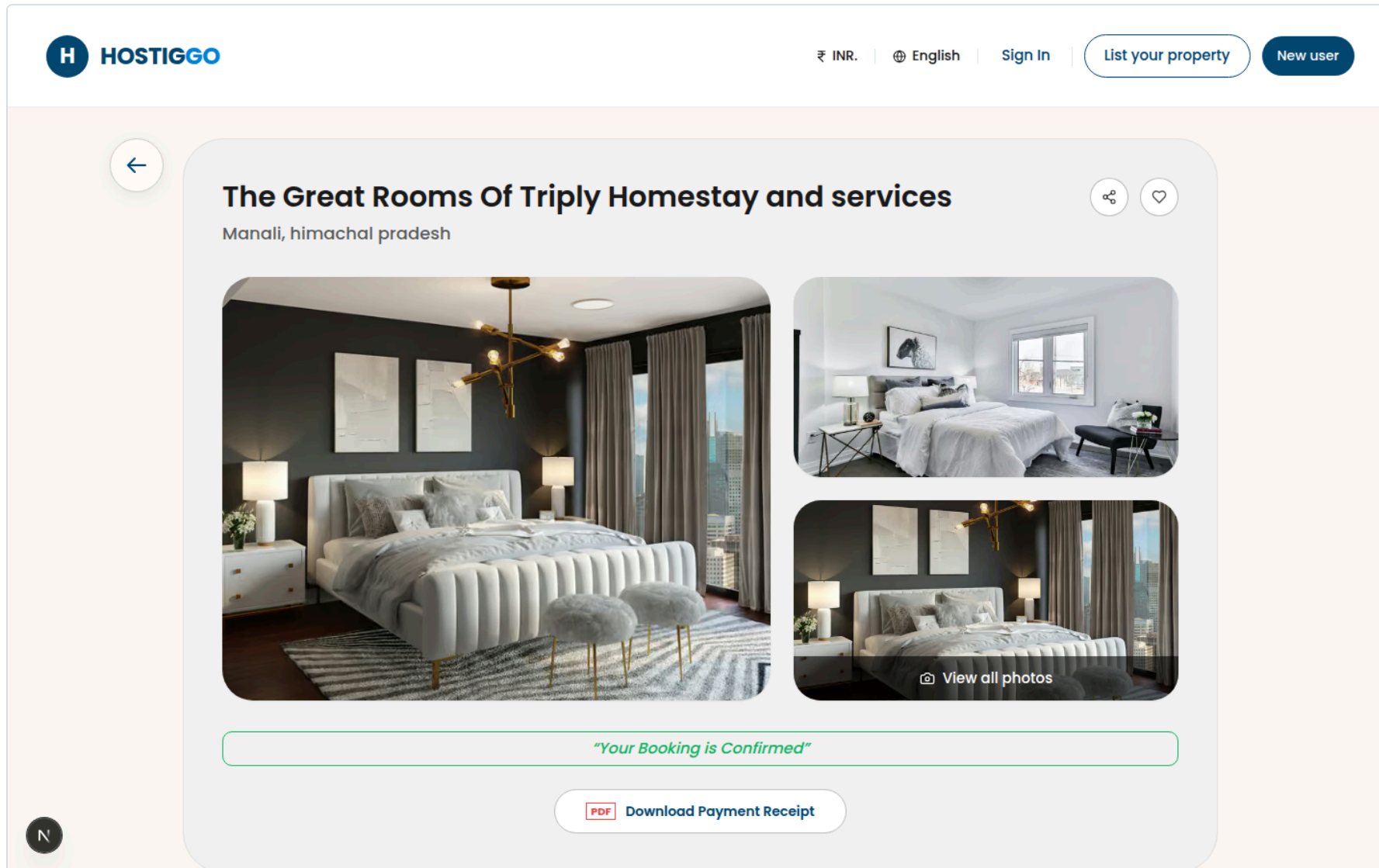
ID	Page / section	Functionality	User action	Expected	Actual	Status
F108	Host wizard	Details step	Title/description limits	50 / 500 chars; required	Correct	PASS
F109	Host wizard	House rules times	Type "banana"	Time validation	Free text accepted (BUG-019)	FAIL
F110	Host wizard	Photos / location map / address	Upload, map, autocomplete	Works	Not exercised (storage, Google Maps)	NOT TESTED
F111	Host wizard	Publish listing	Finish	Listing created	NOT EXECUTED - creates production data	NOT TESTED
F112	Host wizard	AI import (List with AI)	Paste URL	Import	AI_LISTER_URL not set; not exercised	NOT TESTED
F113	Host dashboard	Listings / Bookings / Earnings empty states	Open (signed in)	Empty state	Render correctly [mocked empty]	PASS
F114	Host dashboard	Calendar+iCal, reviews, chat, payouts, discounts & add-ons manager, delist	Use	Works	Not exercised (backend / destructive)	NOT TESTED
F115	API	Token verification on money endpoints	Call w/o token	401	reserve/cancel/refund/payout/change-password → 401	PASS
F116	API	Ownership/identity on other endpoints	Call w/o token with userId	401/403	Proceeds (BUG-001/002/003)	FAIL
F117	API	Razorpay webhook signature	Bad/missing signature	Reject	400	PASS
F118	API	Malformed input	Bad JSON / wrong content-type	400/415	500 with raw message (BUG-025)	FAIL
F119	Errors	Branded 404	Unknown URL	404 page	Works	PASS
F120	Errors	App error boundaries (error.tsx / global-error.tsx)	Force render error	Friendly page	Could not trigger a render error	NOT TESTED
F121	SEO	robots.txt / sitemap.xml / per-page titles	Request	Present, unique	robots 200; no sitemap; 30+ pages share the default <title>; property pages are client-rendered (UX-11)	FAIL

Appendix 2 — Environment and reproduction

- Production build: `npm ci && NEXT_PUBLIC_SUPABASE_URL=http://127.0.0.1:54321 NEXT_PUBLIC_SUPABASE_ANON_KEY=x SUPABASE_SERVICE_ROLE_KEY=x npm run build && npx next start` (Supabase deliberately pointed at a dead address).
- Browser: Playwright-core driving Chromium (headless). Viewports 1440×900, 768×1024, 390×844 (+ 320/360/375/414 for sign-in). Backend mocks intercept `/api/search`, `/api/locations`, `/api/amenities`, `/api/hotels/*`, `/api/users`, `/api/feedback`, `/api/bookings/*`.
- Fake session: `localStorage["hostiggo:user-id"] + ["hostiggo:access-token"]` (test browser only).
- API probing: `curl` against `http://localhost:3000/api/*` with an empty JSON body and no `Authorization` header; 58 routes / 83 route-method combinations.
- Test scripts and raw JSON results were kept in the session scratchpad (not committed).

Appendix 3 - Evidence screenshots

BUG-004 - fake "Your Booking is Confirmed" for an invented booking id



H

HOSTIGGO

₹ INR.

English

Sign In

List your property

New user

Reserve

₹2,349

for 15 nights • 2 Adults

Ratings & reviews

4.9

(417)

★★★★★

5

4

3

2

1

Bappi

Lehri

3 weeks ago

★★★★★

We had a wonderful stay at this homestay. The room was clean, spacious, and exactly as shown in the photos. The host was...

Read more

Bappi

Lehri

3 weeks ago

★★★★★

We had a wonderful stay at this homestay. The room was clean, spacious, and exactly as shown in the photos. The host was...

Read more

Bappi

Lehri

3 weeks ago

★★★★★

We had a wonderful stay at this homestay. The room was clean, spacious, and exactly as shown in the photos. The host was...

Read more

Hostiggo - Website QA & Functionality Audit · Page 27 of 30

BUG-007 - mobile sign-in card clipped at 360 px

×

Welcome to,
Hostiggo



Sign in with mobile

Sign in to access personalized travel plan
for you

+91 ▾

Enter Mobile No.

Send OTP

OR

BUG-010 - search API failure shown as "No properties found"



₹ INR. | English | Sign In | [List your property](#) | [New user](#)

×

Add dates → Add dates

1 Adults • 1 Room
0 Children

[Search](#)

Map preview unavailable
Goa • 0 properties

Goa

0 homestays found

Sort By : Recommended ▾

No properties found

Try adjusting your filters or search for a different destination.

[Clear all filters](#)

Filters

[Clear all](#)

Price Range

Min - Max : ₹ 0 - ₹ 100,000

₹0 ▾

₹25k ▾

₹50k ▾

₹75k ▾

₹100k ▾

●

●

MinMax

Popular Filters

[Private room](#) [Shared room](#)

[Free cancellation](#) [Free breakfast](#)

[Double bed](#) [Couple friendly](#) [Free wifi](#)

[Family friendly](#)

Guest ratings

3 ★ or

4 ★

5 ★

[Show Map](#)

Hostiggo - Website QA & Functionality Audit · Page 29 of 30

OBS-01 - "Bookings temporarily unavailable" after choosing dates

Reserve

₹2,000 /night · for 2 nights · 1 Adult

₹2,000 × 2 nights	₹4,000
GST on property (5%)	₹200
Hostiggo service fee (8%)	₹320
GST on service fee (18%)	₹57.6
Total	₹4,577.6

Bookings temporarily unavailable

Instant confirmation

You won't be charged yet

Location

Goa, Goa

Loading map...

View on Google Maps